Atributos de calidad en RECAUDO-T ampliado

Parte 1: Análisis

Variante V5 – Ola de fraudes (Seguridad prioritaria, Disponibilidad secundaria)

David Sànchez,
Felix Siachoque,
Derick Rios

29/09/2026

1. Consulta: el árbol de utilidad

1.1 ¿Qué es y en qué método se usa?

El árbol de utilidad es una herramienta que traduce la idea general de un buen sistema (la utilidad) en escenarios de calidad concretos, medibles y priorizados. Se usa en el **ATAM** (Architecture Tradeoff Analysis Method), el método de evaluación de arquitecturas del Software Engineering Institute (SEI). En el ATAM, construir el árbol es el paso 5 de la fase de evaluación, y sirve para decidir qué escenarios se analizan contra la arquitectura (Kazman, Klein y Clements, 2000; Bass, Clements y Kazman, 2012).

1.2 Niveles

- **Raíz – Utilidad:** representa la calidad global que el negocio espera del sistema.
- **Segundo nivel – Atributos de calidad:** disponibilidad, desempeño, seguridad, modificabilidad, interoperabilidad.
- **Tercer nivel – Refinamientos:** aspectos concretos de cada atributo (por ejemplo, en seguridad: confidencialidad de saldos).
- **Hojas – Escenarios:** situaciones concretas con estímulo, entorno, respuesta y una medida verificable, cada una con su calificación de prioridad.

1.3 ¿Cómo se priorizan los escenarios?

Cada escenario recibe dos calificaciones en escala Alta, Media o Baja (A, M, B): la importancia para el negocio, asignada por los stakeholders, y la dificultad técnica de lograrlo, estimada por el arquitecto. Los escenarios (A, A) son los que más atención requieren; los (A, M) y (M, A) vienen después; los (A, B) son importantes pero fáciles, y los (B, A) suelen posponerse (Bass et al., 2012).

1.4 ¿Por qué priorizar antes de elegir tácticas?

Porque el tiempo y el presupuesto son limitados, y cada táctica tiene costos y efectos sobre otros atributos. Si se eligen tácticas sin prioridad, se corre el riesgo de optimizar lo que no importa (por ejemplo, hacer muy rápida una consulta poco usada) y de introducir compromisos que perjudican lo que sí importa. Priorizar primero permite concentrar el análisis en los escenarios críticos, hacer explícitos los compromisos entre atributos y justificar cada decisión con el negocio.

2. Árbol de utilidad de RECAUDO-T (variante V5)

En la variante V5 el sistema enfrenta clonación de tarjetas, consultas masivas de saldos ajenos y accesos indebidos de empleados. Por eso todos los escenarios de **seguridad** tienen importancia alta. La **disponibilidad** es el atributo secundario: las defensas no pueden dejar a los pasajeros sin validar, así que sus escenarios también tienen importancia alta. Los demás atributos se analizan con importancia media o baja.

```
Utilidad
├─ Seguridad
│  ├─ Protección contra clonación de tarjetas
│  │  └─ S1 (A, A): tarjeta clonada usada en dos validadores; detección < 2 s y bloqueo en toda la red < 60 s
│  ├─ Confidencialidad de saldos
│  │  └─ S2 (A, M): 10.000 consultas automatizadas a tarjetas ajenas; 0 saldos revelados
│  └─ Control de acceso interno
│     └─ S3 (A, B): empleado sin permiso consulta datos; 100 % denegados y registrados
├─ Disponibilidad
│  ├─ Continuidad de la validación
│  │  └─ D1 (A, A): caída de un nodo de validación en hora pico; conmutación < 30 s, 0 transacciones perdidas
│  └─ Operación con red degradada
│     └─ D2 (A, M): validador sin conexión opera en local; 100 % sincronizado < 5 min tras reconexión
├─ Interoperabilidad
│  ├─ Integración con el cable aéreo
│  │  └─ I1 (M, M): descuento de saldo desde el cable aéreo; p95 < 1 s y 0 diferencias en conciliación
│  └─ Recargas desde bancos
│     └─ I2 (M, B): recargas en centavos y en pesos; 0 errores de conversión en 10.000 recargas
├─ Modificabilidad
│  ├─ Cambios de reglas tarifarias
│  │  └─ M1 (M, B): nueva tarifa de la alcaldía aplicada en ≤ 1 día-persona sin redesplegar
│  └─ Evolución de reglas antifraude
│     └─ M2 (M, M): nueva regla de detección de fraude agregada en ≤ 3 días tocando un solo módulo
└─ Desempeño
   ├─ Validación en hora pico
   │  └─ P1 (M, M): 1500 validaciones/s con control antifraude; p95 < 300 ms
   └─ Consulta de saldo en la app
      └─ P2 (B, B): 500 consultas/s en la aplicación; p95 < 1 s
```

Resumen de prioridades. Los escenarios (A, A) son S1 y D1: son los que más trabajo de arquitectura exigen. S3 es (A, B): muy importante y barato de resolver, por lo que debe hacerse primero. P2 (B, B) puede atenderse al final.

3. Escenarios de calidad

A continuación se presenta la ficha de cada uno de los 11 escenarios del árbol.

Escenario S1 – Protección contra clonación de tarjetas

Campo	Contenido
Identificador	S1
Atributo	Seguridad
Fuente del estímulo	Delincuente con una copia clonada de una tarjeta legítima
Estímulo	La misma tarjeta se usa en dos validadores separados por una distancia imposible de recorrer en el tiempo transcurrido (por ejemplo, dos estaciones a 10 km con 3 minutos de diferencia)
Entorno	Operación normal, hora pico
Artefacto	Servicio de validación y motor antifraude
Respuesta	El sistema detecta el uso anómalo, rechaza la segunda validación, pone la tarjeta en la lista negra y la distribuye a todos los validadores, y avisa al titular
Medida de la respuesta	Detección en menos de 2 s; tarjeta bloqueada en el 100 % de los validadores en menos de 60 s; al menos 95 % de los clones detectados en una prueba con 1000 usos simulados
Prioridad	(A, A)

Escenario S2 – Confidencialidad de saldos

Campo	Contenido
Identificador	S2
Atributo	Seguridad
Fuente del estímulo	Bot o script externo que usa la API pública de la aplicación
Estímulo	Envío masivo de consultas de saldo con números de tarjeta secuenciales que no pertenecen al solicitante
Entorno	Operación normal
Artefacto	API de consulta de saldo
Respuesta	El sistema solo entrega el saldo de tarjetas vinculadas a la cuenta autenticada; rechaza las demás y registra el intento
Medida de la respuesta	0 saldos ajenos revelados en una prueba de 10 000 consultas; 100 % de las solicitudes no autorizadas rechazadas con código 403 en menos de 300 ms
Prioridad	(A, M)

Escenario S3 – Control de acceso interno

Campo	Contenido
Identificador	S3
Atributo	Seguridad
Fuente del estímulo	Empleado de atención al cliente
Estímulo	Intenta consultar datos personales y movimientos de un usuario sin tener un caso asignado
Entorno	Operación normal, jornada laboral
Artefacto	Módulo de administración y base de datos de usuarios
Respuesta	El sistema niega el acceso según el rol del empleado, registra el intento y alerta al oficial de seguridad
Medida de la respuesta	100 % de accesos fuera de rol denegados; 100 % registrados en auditoría; alerta enviada en menos de 5 min
Prioridad	(A, B)

Escenario D1 – Continuidad de la validación

Campo	Contenido
Identificador	D1
Atributo	Disponibilidad
Fuente del estímulo	Falla de hardware o software en un servidor
Estímulo	Se cae uno de los nodos del servicio central de validación
Entorno	Hora pico
Artefacto	Servicio central de validación y descuento de saldo
Respuesta	El sistema detecta la falla y traslada el tráfico a un nodo réplica sin intervención humana
Medida de la respuesta	Detección en menos de 5 s; conmutación en menos de 30 s; 0 transacciones perdidas; disponibilidad mensual ≥ 99,95 %
Prioridad	(A, A)

Escenario D2 – Operación con red degradada

Campo	Contenido
Identificador	D2
Atributo	Disponibilidad
Fuente del estímulo	Falla del enlace de comunicaciones
Estímulo	Un validador de bus pierde la conexión con el servidor central
Entorno	Modo degradado
Artefacto	Validador embarcado y servicio de sincronización
Respuesta	El validador sigue aceptando pasajes con las reglas locales, guarda las transacciones en una cola y las reenvía al recuperar la conexión
Medida de la respuesta	Operación local hasta 2 h; 100 % de transacciones sincronizadas en menos de 5 min tras la reconexión; 0 descuentos duplicados
Prioridad	(A, M)

Escenario I1 – Integración con el cable aéreo

Campo	Contenido
Identificador	I1
Atributo	Interoperabilidad
Fuente del estímulo	Sistema del operador del cable aéreo
Estímulo	Solicita consultar y descontar el saldo de una tarjeta al pasar por su torniquete
Entorno	Operación normal
Artefacto	API de integración con operadores externos
Respuesta	RECAUDO-T autentica al operador, valida antifraude, descuenta el saldo y confirma la operación
Medida de la respuesta	p95 menor a 1 s; 0 diferencias en la conciliación diaria entre ambos sistemas
Prioridad	(M, M)

Escenario I2 – Recargas desde bancos

Campo	Contenido
Identificador	I2
Atributo	Interoperabilidad
Fuente del estímulo	Banco A (reporta en centavos) y banco B (reporta en pesos)
Estímulo	Envían archivos o mensajes de recarga cada uno en su propio formato
Entorno	Operación normal, cierre diario
Artefacto	Módulo de recepción de recargas
Respuesta	El sistema convierte ambos formatos al modelo interno y acredita el saldo correcto
Medida de la respuesta	0 errores de conversión en una prueba de 10 000 recargas mezcladas; acreditación en menos de 60 s
Prioridad	(M, B)

Escenario M1 – Cambios de reglas tarifarias

Campo	Contenido
Identificador	M1
Atributo	Modificabilidad
Fuente del estímulo	Alcaldía
Estímulo	Cambia el valor del pasaje para estudiantes en hora valle
Entorno	Operación normal
Artefacto	Módulo de cálculo de tarifas
Respuesta	El cambio se configura y entra en vigor sin modificar código ni reiniciar el servicio
Medida de la respuesta	Máximo 1 día-persona de esfuerzo; 0 redespliegues; 0 regresiones en las pruebas de tarifas existentes
Prioridad	(M, B)

Escenario M2 – Evolución de reglas antifraude

Campo	Contenido
Identificador	M2
Atributo	Modificabilidad
Fuente del estímulo	Equipo de seguridad
Estímulo	Solicita agregar una regla nueva (por ejemplo, más de 5 recargas en 10 min desde el mismo punto)

Campo	Contenido
Entorno	Tiempo de desarrollo
Artefacto	Motor antifraude
Respuesta	La regla se agrega sin tocar la validación ni el cálculo de tarifas
Medida de la respuesta	Máximo 3 días-persona; cambios en 1 solo módulo; 0 fallas en las pruebas de regresión
Prioridad	(M, M)

Escenario P1 – Validación en hora pico

Campo	Contenido
Identificador	P1
Atributo	Desempeño
Fuente del estímulo	Usuarios en torniquetes y buses
Estímulo	1500 validaciones por segundo durante 30 minutos
Entorno	Hora pico de la mañana
Artefacto	Servicio de validación
Respuesta	El sistema valida, aplica tarifa, revisa antifraude y descuenta el saldo de cada pasaje
Medida de la respuesta	Latencia p95 menor a 300 ms; 0 validaciones rechazadas por saturación
Prioridad	(M, M)

Escenario P2 – Consulta de saldo en la app

Campo	Contenido
Identificador	P2
Atributo	Desempeño
Fuente del estímulo	Usuarios de la aplicación móvil
Estímulo	500 consultas de saldo por segundo
Entorno	Operación normal, inicio de mes
Artefacto	Servicio de consulta de saldo
Respuesta	El sistema responde el saldo sin afectar la validación
Medida de la respuesta	Latencia p95 menor a 1 s; latencia de validación sin variación mayor a 10 %
Prioridad	(B, B)

4. Tácticas

Para cada escenario se eligió una táctica de los árboles vistos en clase.

Esc.	Táctica elegida	Por qué esta táctica resuelve el escenario	Alternativa descartada y por qué
S1	**Detectar ataques** (detección de anomalías de uso) con reacción de **revocar acceso** (lista negra)	Un clon usa las mismas credenciales que la tarjeta real, así que no se distingue en el momento de leerla; se distingue por el patrón de uso (velocidad imposible entre estaciones). Detectar y revocar corta el fraude en segundos en toda la red.	Reemplazar todas las tarjetas por unas con criptografía más fuerte: resuelve la causa, pero cuesta millones de tarjetas y tarda meses; se deja como medida de largo plazo.
S2	**Autorizar actores** (el saldo solo se entrega al titular vinculado)	El problema es que cualquiera puede preguntar por cualquier tarjeta. Si la API exige sesión y verifica que la tarjeta esté vinculada a esa cuenta, las consultas ajenas fallan sin importar cuántas se hagan.	Solo limitar la tasa de peticiones por IP: frena el ataque pero no lo elimina, porque el atacante puede repartir las consultas entre muchas IP y seguir obteniendo saldos.
S3	**Limitar el acceso** (mínimo privilegio por rol)	Cada empleado solo ve los datos que su rol y su caso asignado necesitan; el acceso indebido se bloquea antes de ocurrir.	Solo registro de auditoría: detecta el abuso después de que el dato ya se vio. Se usa como complemento, no como táctica principal.
D1	**Redundancia activa** (con heartbeat para detectar la falla)	Con réplicas procesando en paralelo, la caída de un nodo no interrumpe la validación; el heartbeat detecta la falla en segundos y el balanceador saca el nodo.	Redundancia pasiva (respaldo en frío): arrancar el respaldo toma minutos, y cada minuto de caída se traduce en tarjetas sin validar y en pasajes perdidos.
D2	**Reintentar** (cola local en el validador y reenvío idempotente)	El validador no depende de la red para cobrar: guarda las transacciones y las reenvía; con identificadores únicos el reenvío no genera descuentos dobles.	Rechazar validaciones mientras no haya red: es más seguro frente a clones, pero deja a los pasajeros sin servicio, lo cual la variante también castiga.
I1	**Orquestación**	El descuento del cable aéreo requiere varios pasos en orden (autenticar al operador, revisar antifraude, descontar, confirmar). Un orquestador coordina esos pasos y deshace la operación si alguno falla.	Dar al cable aéreo acceso directo a la base de datos de saldos: es rápido de montar, pero rompe el control antifraude y expone datos sensibles.
I2	**Adaptar la interfaz** (un adaptador por banco)	Cada adaptador traduce el formato de su banco (centavos o pesos) al modelo interno; el resto del sistema solo conoce un formato.	Pedir a los bancos que cambien su formato: no depende de RECAUDO-T y puede tardar meses o no ocurrir.
M1	**Diferir el enlace** (reglas de tarifa en configuración, leídas en tiempo de ejecución)	Las tarifas se guardan como una tabla de reglas (tipo de usuario, franja, transbordos, valor). Un cambio de la alcaldía se vuelve una actualización de datos, no un cambio de código.	Modificar el código en cada cambio: con cambios casi mensuales multiplica los redespliegues y el riesgo de errores.
M2	**Aumentar la cohesión** (aislar el motor antifraude)	Si todas las reglas antifraude viven en un módulo con una interfaz clara, una regla	Usar un intermediario: agrega una capa, pero si las reglas siguen repartidas en varios módulos el

Esc.	Táctica elegida	Por qué esta táctica resuelve el escenario	Alternativa descartada y por qué
		nueva solo toca ese módulo y no afecta la validación ni las tarifas.	cambio sigue tocando muchos sitios.
P1	**Introducir concurrencia** (procesamiento paralelo particionado por número de tarjeta)	Particionar por tarjeta permite atender muchas validaciones a la vez, y las de una misma tarjeta caen en la misma partición, lo que evita condiciones de carrera en el saldo y en la detección de doble uso.	Aumentar recursos de un solo servidor (escalar vertical): tiene un techo y no ayuda a la disponibilidad.
P2	**Mantener múltiples copias de datos** (réplica de lectura para consultas)	Las consultas de la app van a una réplica y no compiten con las validaciones por la base principal.	Priorizar eventos (darle prioridad baja a la app): protege la validación pero empeora la experiencia de la app sin aumentar la capacidad.

5. Compromisos entre atributos

5.1 Matriz de compromisos

D = Disponibilidad, I = Interoperabilidad, M = Modificabilidad, P = Desempeño, S = Seguridad. ↑ mejora, ↓ empeora, = sin efecto relevante.

Táctica	D	I	M	P	S
Detectar ataques + revocar (S1)	=	=	↓	↓	↑
Autorizar actores (S2)	=	↓	=	↓	↑
Limitar el acceso por rol (S3)	=	=	↓	=	↑
Redundancia activa (D1)	↑	=	=	↓	↓
Reintentar con cola local (D2)	↑	=	=	=	↓
Orquestación (I1)	↓	↑	↑	↓	↑
Adaptar la interfaz (I2)	=	↑	↑	↓	=
Diferir el enlace (M1)	=	=	↑	↓	↓
Aumentar la cohesión (M2)	=	=	↑	=	↑
Introducir concurrencia (P1)	↑	=	↓	↑	↓
Múltiples copias de datos (P2)	↑	=	↓	↑	↓

Lectura de la matriz. Casi todas las tácticas de seguridad empeoran el desempeño o la modificabilidad, porque agregan verificaciones y controles. A su vez, las tácticas de disponibilidad y desempeño (redundancia, copias de datos, operación sin red) tienden a empeorar la seguridad, porque multiplican las copias de datos sensibles o abren ventanas sin control. Esa tensión entre seguridad y disponibilidad es justamente la de la variante V5.

5.2 Análisis de los compromisos principales

Táctica	Mejora	Empeora	Por qué ocurre	Cómo cuantificarlo (medida y prueba)
Detectar ataques + revocar (S1)	Seguridad	Desempeño	Cada validación debe consultar el historial reciente de la tarjeta y evaluar reglas antes de aprobar el pasaje, lo que agrega tiempo de procesamiento en el camino crítico.	Latencia p95 de validación con y sin el detector activo, en una prueba de carga de 1500 validaciones/s durante 30 min. Se reporta el aumento en milisegundos y en porcentaje.
Reintentar con cola local (D2)	Disponibilidad	Seguridad	Mientras el validador está sin red no puede consultar la lista negra actualizada, así que un clon puede usarse varias veces antes de ser detectado.	Número de usos fraudulentos aceptados durante la desconexión, en una prueba que corta la red por 30 min e inyecta 100 usos de tarjetas clonadas.
Redundancia activa (D1)	Disponibilidad	Desempeño y Seguridad	Las réplicas deben mantener el saldo sincronizado (cada escritura se confirma en más de un nodo) y cada réplica es una copia más de datos sensibles que hay que proteger.	Latencia p95 de descuento con 1 y con 2 réplicas sincrónicas; conteo de copias de datos sensibles en el inventario de activos.
Diferir el enlace (M1)	Modificabilidad	Desempeño y Seguridad	Leer e interpretar reglas en tiempo de ejecución es más lento que un valor fijo en código, y la tabla de tarifas se vuelve un blanco: quien la modifique puede cambiar el cobro.	Tiempo de cálculo de tarifa (µs) con reglas en código vs. en tabla, con 1 millón de cálculos; prueba de que un usuario sin rol de tarifas no puede editar la tabla.
Múltiples copias de datos (P2)	Desempeño	Consistencia / Seguridad	La réplica puede mostrar un saldo desactualizado unos segundos y amplía la superficie de ataque.	Retraso de replicación (s) medido durante la prueba de 500 consultas/s; porcentaje de consultas que muestran un saldo distinto al de la base principal.

6. Selección para la práctica

6.1 Escenarios que se implementarán en la Parte 2

Escenario	Atributo	Prioridad	Qué se implementará
S1	Seguridad (prioritario)	(A, A)	Detector de uso imposible (misma tarjeta en dos estaciones en un tiempo menor al de viaje) y lista negra que se propaga a los validadores.
D2	Disponibilidad (secundario)	(A, M)	Validador con cola local que sigue operando sin red y reenvía las transacciones con identificador único al reconectarse.
P1	Desempeño	(M, M)	Servicio de validación con procesamiento concurrente particionado por tarjeta, sometido a una prueba de carga de 1500 validaciones/s.

Los tres escenarios son de atributos distintos y S1 pertenece al atributo prioritario de la variante (seguridad).

6.2 Compromiso que se medirá

Se medirá el compromiso entre **Seguridad y Desempeño** causado por la táctica "detectar ataques" de S1. La prueba consiste en correr la carga de P1 (1500 validaciones/s durante 30 minutos) dos veces: una sin el detector de clonación y otra con el detector activo. Se comparará la latencia p95 de validación y el porcentaje de clones detectados. Así se sabrá cuántos milisegundos cuesta la protección y si con el detector activo todavía se cumple la meta de p95 menor a 300 ms.

6.3 Justificación de la selección

- **S1** es el escenario (A, A) del atributo prioritario: la clonación es el fraude que más dinero cuesta y el más difícil de controlar, así que es donde la arquitectura debe pensar más.
- **D2** es de alta importancia en el atributo secundario y permite ver en la práctica la tensión central de V5: seguir cobrando sin red frente a no poder verificar clones. Se prefirió sobre D1 (A, A) porque D1 requiere infraestructura de varios servidores difícil de montar en la práctica, mientras que D2 se puede demostrar con un solo validador simulado.
- **P1** es necesario para medir el compromiso: sin una prueba de carga no se puede saber cuánto afecta la detección de fraude al tiempo de validación.
- Se descartaron S3 (A, B) porque, aunque es importante, es barato y no genera un compromiso interesante de medir; y P2, M1 e I2 porque tienen prioridad media o baja en esta variante.

Referencias

Bass, L., Clements, P. y Kazman, R. (2012). Software Architecture in Practice (3.ª ed.). Addison-Wesley. Capítulo 21: Architecture Evaluation.

Kazman, R., Klein, M. y Clements, P. (2000). ATAM: Method for Architecture Evaluation (CMU/SEI-2000-TR-004). Software Engineering Institute, Carnegie Mellon University.